

WEB APPLICATION DEVELOPMENT

LAB 6 – INCLASS

 **Login**

Student Management System

☒ You have been logged out successfully

Username

Password

☐ Remember me

Login

Demo Credentials:
Admin: username: admin / password: password123
User: username: john / password: password123

Login with user permission

 **Login**

Student Management System

☒ You have been logged out successfully

Username

Password

☐ Remember me

Login

Demo Credentials:
Admin: username: admin / password: password123
User: username: john / password: password123

Login with administration permission

Student Management SystemAdmin User **admin** Logout

Welcome back, Admin User!
Here's what's happening with your students today.

 **11**
Total Students

Quick Actions

[View All Students](#)[Add New Student](#)[Search Students](#)

Dashboard with administration permission

I. Login with permission

1. Browser → POST /login with username, password
2. LoginController.doPost() receives request
3. Controller validates: If empty fields → set error, forward back to login.jsp
4. UserDAO.authenticate(username, password)
5. DAO queries database: If match → return User. Otherwise, return null
6. Controller checks user: If user == null → set error, forward login.jsp
7. If authentication is successful:
 - Invalidate old session
 - Create new session
 - Set session attributes: user, role, fullName
 - Set session timeout = 30 minutes
8. Controller redirects based on role:
 - If admin → /dashboard
 - If normal user → /student?action=list

II. Servlet filter

1. Browser requests ANY URL
2. Filter intercepts request *before* servlet
3. Filter checks: If request URI is /login, /register, /assets/* → allow
4. Filter retrieves session: HttpSession session = request.getSession(false)
5. Check if user logged in: If session == null OR session.getAttribute("user") == null → redirect login
6. If logged in → continue chain (forward to controller/servlet)

III. Role-based access control

1. Request comes in → Filter runs
2. Filter checks the session role: String role = (String) session.getAttribute("role");
3. Filter checks protected route:
 - If user tries to access admin URL: If role != "admin" → send 403 or redirect to unauthorized.jsp
 - If user tries to access student URL: If role == null → redirect login
4. If authorization passes → filter calls:
 - chain.doFilter(request, response) → continue to controller